Efficient and Secure Post-Quantum Certificateless Signcryption With Linkability for IoMT

Shiyuan Xu, *Graduate Student Member, IEEE*, Xue Chen, *Graduate Student Member, IEEE*, Yu Guo, *Member, IEEE*, Siu-Ming Yiu, *Member, IEEE*, Shang Gao, *Member, IEEE*, and Bin Xiao, *Fellow, IEEE*

***Abstract*—The Internet of Medical Things (IoMT) has gained significant research focus in both academic and medical institutions. Nevertheless, the sensitive data involved in IoMT raises concerns regarding user validation and data privacy. To address these concerns, certificateless signcryption (CLSC) has emerged as a promising solution, offering authenticity, confidentiality, and unforgeability. Unfortunately, most existing CLSC schemes are impractical for IoMT due to their heavy computational and storage requirements. Additionally, these schemes are vulnerable to quantum computing attacks. Therefore, research focusing on designing an efficient post-quantum CLSC scheme is still far-reaching. In this work, we propose PQ-CLSCL, a novel post-quantum CLSC scheme with linkability for IoMT. Our proposed design facilitates secure transmission of medical data between physicians and patients, effectively validating user legitimacy and minimizing the risk of private information leakage. To achieve this, we leverage lattice sampling algorithms and hash functions to generate the partial secret key, then employ the sign-then-encrypt method and design a link label. We also formalize and prove the security of our design, including indistinguishability against chosen-ciphertext attacks (IND-CCA2), existential unforgeability against chosen-message attacks (EU-CMA), and linkability. Finally, through comprehensive performance evaluation, our computation overhead is just 5% of other existing schemes. The evaluation results demonstrate that our solution is practical and efficient.**

***Index Terms*—Certificateless signcryption, internet of medical things, linkability, lattice, information security, applied cryptography.**

I. Introduction

THE Internet of Medical Things, a new concept emerging from the combination of medical sensor devices and the Internet of Things, providing patients with diverse and flexible treatment options [1], [2]. A traditional IoMT scenario consists of three types of entities as depicted in Fig. 1, including patient, medical monitoring device (MMD), and physician [3], [4]. The medical monitoring device worn by the patient transmits data from various body indicators via the Internet to the hospital for storage. Doctors can access the patient's medical health data by accessing the database of patient records, and then use Artificial Intelligence algorithms to analyze the patient's data, point out possible conditions, provide remote treatment, prescribe potential medications, and make near real-time decisions for the patient. As the patient recovers, the doctor can also remotely ask the patient for advice and precautions to prevent the disease.

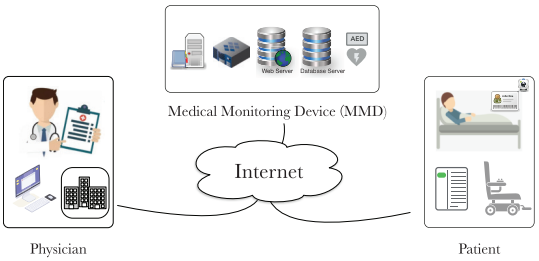

Fig. 1. A traditional framework of IoMT.

IoMT provides patients with convenient and reliable healthcare services, enabling them to prevent or treat diseases remotely and in a timely manner [5]. However, the data transmission mode of IoMT can be intercepted or even tampered with by an adversary during the communication process of the patient's medical information data, resulting in the leakage of a large amount of sensitive information such as the patient's personal data [6]. This could lead to doctors making incorrect diagnoses of patients' conditions. For example, if an adversary tampers with the data of medical monitoring devices and sends some worsened physical indicators to the hospital, the doctor may think that the patient's condition has worsened after the analysis and make a wrong diagnosis, thus affecting the patient's health [7]. Therefore, it is significant and challenging to transmit and protect medical data securely.

Numerous scholars have adopted digital signatures [8], [9] and public key encryption [10] to secure data transmissions between medical monitoring devices and users for user authentication and personal information protection. However, directly combining these cryptographic primitives in one scheme will

Received 24 June 2024; revised 27 September 2024 and 22 November 2024; accepted 11 December 2024. Date of publication 18 December 2024; date of current version 10 January 2025. This work was supported in part by the HKU-SCF FinTech Academy, Shenzhen-Hong Kong-Macao Science and Technology Plan Project (Category C) under Project SGDX20210823103537030; in part by the Theme-Based Research Scheme under Grant T35-710/20-R; and in part by the National Natural Science Foundation of China under Grant 62102035. The associate editor coordinating the review of this article and approving it for publication was Dr. Jason (Minhui) Xue. *(Corresponding authors: Yu Guo; Siu-Ming Yiu.)*

Shiyuan Xu, Xue Chen, and Siu-Ming Yiu are with the Department of Computer Science, School of Computing and Data Science, The University of Hong Kong, Hong Kong (e-mail: syxu2@cs.hku.hk; xchen.serena666@connect.hku.hk; smyiu@cs.hku.hk).

Yu Guo is with the School of Artificial Intelligence, Beijing Normal University, Beijing 100875, China (e-mail: yuguo@bnu.edu.cn).

Shang Gao and Bin Xiao are with the Department of Computing, The Hong Kong Polytechnic University, Hong Kong (e-mail: shang-jason.gao@polyu.edu.hk; b.xiao@polyu.edu.hk).

Digital Object Identifier 10.1109/TIFS.2024.3520007

© 2024 The Authors. This work is licensed under a Creative Commons Attribution 4.0 License.
For more information, see https://creativecommons.org/licenses/by/4.0/

significantly increase the computational and storage overhead, which is impractical for IoMT scenarios. Zheng [11] formalized an innovative primitive, namely signcryption, which can perform both encryption and signature operations. It not only satisfies the authenticity and confidentiality requirements but is also more effective than the traditional 'sign then encrypt' or 'encrypt then sign' methodologies. Classical signcryption construction mainly includes two main categories, which are identity-based public key cryptography (IB-PKC) and public key infrastructure (PKI). Nevertheless, PKI-based CLSC schemes require a Certificate Authority (CA) to distribute a large number of certificates to users, resulting in complex management and high storage overhead. In addition, IB-PKC-based primitives face key escrow issues, where the key generation center (KGC) can arbitrarily decrypt the user's message and forge its signature, posing to severe security risks.

To overcome the above-mentioned hindrances, Al-Riyami and Paterson [12] presented a certificateless public key cryptography (CL-PKC) primitive. Unlike IB-PKC, it introduces the semi-honest KGC with its master secret key, which is only responsible for generating part secret key. Then, Barbosa and Farshim [13] formalized the concept of CLSC based on bilinear pairing, where a user's secret key consists of a secret key value of its own choice and a partial secret key. Since then, numerous novel CLSC schemes were proposed [14], [15], [16], [17]. However, these schemes either require significant computational overhead or fail to provide data confidentiality in IoMT scenarios. Besides, most schemes are vulnerable to quantum attacks [18], which makes it still insecure and impractical.

However, there are circumstances where it is crucial to determine if different messages come from the same sender. With the vast amount of medical data available, it is time-consuming for a physician to download and decrypt multiple medical data to determine if they correspond to a specific patient [19]. To bridge the gap, the notion of signature linkability was formalized, where a user generates several messages during a particular event, these messages will be associated with one another [20]. As such, physicians can directly ascertain whether multiple sets of medical data pertain to the same patient, significantly reducing computational overhead. To the best of our knowledge, there does not exist a lattice-based signcryption scheme that provides this property [21], [22], [23], [24], [25], [26], [27], [28], [29], despite its practical benefits for privacy preservation in IoMT.

A. Our Motivation

IoMT offers patients more reliable and convenient healthcare services, enabling them to receive timely treatment from doctors. However, transmitting medical data in IoMT presents significant security and privacy challenges. For instance, data can be tampered with by malicious adversaries, and patients' sensitive personal information may be leaked. These issues pose a bottleneck to the development of IoMT. Therefore, ensuring the confidentiality and integrity of medical data while achieving quantum safety remains a critical concern.

In our design, we prioritize practicality, efficiency, and security. To get around these concerns, our intuition is to develop a signcryption primitive that simultaneously performs the roles of public key encryption and digital signature. In addition, we incorporate lattice hardness to resist quantum attacks. To simplify the complexity of key management and deployment, a certificateless framework is promising as it avoids the certificate management challenges associated with public key infrastructure (PKI). In terms of security requirements, our design is built to be quantum-resistant and must guarantee confidentiality and unforgeability for medical data. Considering the real-world application, we also incorporate the linkability so that physicians can directly determine whether multiple sets of data are related to the same patient.

B. Our Contribution

We summarize the fourfold contribution to this work below.

- We propose the first post-quantum certificateless signcryption with linkability, named PQ-CLSCL, designed to secure medical data transmission between monitoring devices and users (patients and physicians) in IoMT scenarios. It validates user legitimacy and mitigates the risk of private information leakage while quickly determining if multiple ciphertexts belong to the same patient. To the best of our knowledge, this is the first quantum-safe certificateless signcryption protocol for IoMT.
- The proposed scheme combines lattice-based certificateless signature and public key encryption into a single primitive. It offers several security advantages, including confidentiality, unforgeability, linkability, and authenticity of transmitted data under two types of attacks.
- Our scheme has been proven to satisfy IND-CCA2, EU-CMA, and linkability in the random oracle model (ROM). Through rigorous security analysis, we demonstrate that the IND-CCA2, EU-CMA and linkability of our PQ-CLSCL primitive can be reduced to the hardness of LWE and SIS, respectively. We also give an informal analysis of the Man-in-the-middle attack and Impersonation attack. By conducting a security comparison, our scheme fulfills the properties of IND-CCA2, UF-CMA, quantum resistance, and linkability simultaneously, surpassing the capabilities of prior arts.
- Through comprehensive experiments, we have determined that our signcryption and unsigncryption overheads are 21.067 ms and 10.567 ms, respectively, resulting in a total computation overhead of 31.634 ms. Comparative analysis with other signcryption protocols [21], [22], [23], [24], [25], [26], [27], [28], [29], [30], [31], [32] reveals that our PQ-CLSCL scheme outperforms the overhead of all other lattice-based solutions. It is worth noting that our signcryption and unsigncryption overheads are only 0.07 to 1.0 times and 0.02 to 1.0 times compared to prior arts, respectively. Our computation overhead is just 0.05 to 1.0 times of existing lattice-based signcryption schemes.

C. Technical Overview

Traditional lattice-based signcryption schemes typically employ the encrypt-then-sign approach [33], [34]. However,